

Report sulla Sicurezza Informatica: Analisi delle CVE in ambiente Windows 10

1. Introduzione: Cosa sono le CVE?

L'acronimo **CVE** sta per **Common Vulnerabilities and Exposures** (Vulnerabilità ed Esposizioni Comuni). È un sistema internazionale di riferimento gestito dalla *MITRE Corporation* (finanziata dal governo USA) che fornisce un metodo standardizzato per identificare, definire e catalogare le vulnerabilità di sicurezza informatica note pubblicamente.

Perché sono importanti?

Prima dell'esistenza delle CVE, ogni fornitore di sicurezza usava nomi diversi per lo stesso problema (es. "Microsoft Bug X", "Symantec Virus Y"). Il sistema CVE assegna a ogni vulnerabilità un identificativo unico nel formato:

CVE-ANNO-NUMERO (es. CVE-2017-0144)

Questo permette a ricercatori, amministratori di sistema e fornitori di software di parlare la stessa lingua, coordinare le patch e valutare la gravità del problema tramite il punteggio **CVSS** (Common Vulnerability Scoring System), che va da 0.0 a 10.0 (Critico).

2. Le CVE di Maggiore Rilevanza su Windows 10

Windows 10, essendo uno dei sistemi operativi più diffusi al mondo, è stato soggetto a numerose vulnerabilità critiche. Di seguito sono elencate alcune delle più significative per impatto storico e tecnico:

CVE ID	Nome / Soprannome	Gravità (CVSS)	Descrizione Breve
CVE-2017-0144	EternalBlue	9.3 (Critico)	Esecuzione di codice remoto (RCE) tramite il protocollo SMBv1. È la base di WannaCry.

CVE-2019-0708	BlueKeep	9.8 (Critico)	Vulnerabilità "Wormable" nei servizi di Desktop Remoto (RDP). Permette l'accesso senza autenticazione.
CVE-2020-0601	CurveBall	8.1 (Alto)	Errore nella CryptoAPI di Windows (crypt32.dll). Permetteva di falsificare certificati digitali e far apparire malware come software legittimo.
CVE-2021-34527	PrintNightmare	8.8 (Alto)	Vulnerabilità nello spooler di stampa. Permetteva a un attaccante con accesso limitato di diventare amministratore di dominio.
CVE-2022-30190	Follina	7.8 (Alto)	Esecuzione di codice tramite lo strumento di diagnostica MSDT, spesso attivato tramite documenti Word malevoli.

3. Danni Causati e Conseguenze

Le vulnerabilità sopra citate non sono rimaste teoriche, ma hanno causato danni reali e ingenti a livello globale:

1. **Interruzione di Servizi Essenziali:** L'esempio più lampante è l'attacco ransomware **WannaCry** (basato su EternalBlue), che ha bloccato ospedali (NHS nel Regno Unito),

ferrovie e fabbriche automobilistiche, cifrando i dati vitali.

2. **Perdita Economica:** Si stima che i danni globali causati dagli attacchi derivanti da queste CVE ammontino a miliardi di dollari tra riscatti pagati, costi di ripristino e perdita di produttività.
3. **Furto di Proprietà Intellettuale:** Vulnerabilità come *Follina* sono state utilizzate da gruppi APT (Advanced Persistent Threat) per spionaggio industriale, permettendo l'accesso silenzioso alle reti aziendali.
4. **Compromissione della Fiducia:** *CurveBall* ha minato la fiducia nei certificati digitali, componente fondamentale per la sicurezza delle transazioni web e dell'aggiornamento software.

4. Remediation: Cosa è stato fatto

Per contrastare queste minacce, Microsoft e l'industria della sicurezza hanno adottato diverse misure:

- **Patch Tuesday:** Microsoft rilascia aggiornamenti cumulativi ogni secondo martedì del mese. Tutte le CVE citate sono state corrette tramite queste patch.
- **Disabilitazione di Protocolli Obsoleti:** A seguito di EternalBlue, Microsoft ha disabilitato il protocollo **SMBv1** per impostazione predefinita nelle versioni recenti di Windows 10 e 11.
- **Mitigazioni "Out-of-Band":** Per casi gravissimi (come PrintNightmare), sono state rilasciate patch di emergenza fuori dal ciclo normale.
- **Miglioramenti Architetturelli:** L'introduzione di *Windows Defender Exploit Guard* e *Attack Surface Reduction (ASR)* aiuta a bloccare comportamenti anomali (come un file Word che lancia processi non autorizzati) anche se la vulnerabilità non è ancora nota (Zero-day).

5. Focus Tecnico: L'Exploit EternalBlue (CVE-2017-0144)

Sebbene associato spesso a Windows 7, EternalBlue colpiva anche le prime versioni di Windows 10 (pre-patch) e Windows Server. È considerato l'exploit più sofisticato e dannoso dell'ultimo decennio.

Origine

L'exploit è stato sviluppato originariamente dalla **NSA** (National Security Agency) e successivamente rubato e rilasciato pubblicamente dal gruppo hacker noto come **The Shadow Brokers** nell'aprile 2017.

Come funziona (Analisi Tecnica)

EternalBlue sfrutta una vulnerabilità nell'implementazione Microsoft del protocollo **SMBv1**

(Server Message Block), utilizzato per la condivisione di file e stampanti in rete.

1. **Buffer Overflow:** L'attaccante invia pacchetti appositamente "malformati" alla porta **445** del target.
2. **Il Bug:** Il driver del kernel di Windows srv.sys gestiva in modo errato questi pacchetti durante la conversione di alcuni dati (FEA - File Extended Attributes).
3. **Memory Corruption:** Questo errore permetteva di scrivere dati arbitrari in un'area di memoria del kernel che non avrebbe dovuto essere accessibile.
4. **Esecuzione Codice:** L'attaccante poteva iniettare ed eseguire il proprio codice (shellcode) con privilegi di **SYSTEM** (superiori all'amministratore).

Perché è "Wormable"?

A differenza di un virus che richiede un click dell'utente (one-click), EternalBlue permette all'attaccante di scansionare internet o la rete locale, trovare la porta 445 aperta e infettare la macchina autonomamente (zero-click). La macchina infetta scansiona poi a sua volta altre macchine, creando una reazione a catena esponenziale (come visto con WannaCry).

Stato Attuale

Oggi, un sistema Windows 10 aggiornato è immune a EternalBlue sia grazie alle patch di sicurezza (MS17-010), sia perché il protocollo SMBv1 è solitamente disattivato. Tuttavia, macchine legacy non aggiornate rimangono a rischio.

Conclusione

La gestione delle CVE su Windows 10 dimostra che la sicurezza non è un prodotto statico ma un processo continuo. La rapidità nell'applicazione delle patch e la disabilitazione dei servizi non necessari (hardening) rimangono le difese primarie contro exploit devastanti come EternalBlue.